COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Other Malware Types

Mestre CyberSec · **Aula 2.4 — Other Malware Types** (7:32) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Keylogger: grava digitação — rouba senha em texto claro. Logic bomb: detonada por evento (data, demissão, tecla) — dorme até o gatilho. Rootkit: esconde no KERNEL — invisível pra antivírus comum (precisa de limpeza/reinstall). Trojan: finge ser legítimo. Backdoor: porta que o ata

💡 Highlights que a prova CompTIA cobra

- Rootkit esconde no KERNEL do sistema: quase invisível (boot from known-good media pra detectar)
- Keylogger: grava tudo em texto claro — rouba senha no envio
- Logic bomb: detonada por EVENTO (data/demissão/action)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'malware that hides itself within the OS kernel' = rootkit
- 'dormant until triggered by a specific event' = logic bomb

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Other Malware Types)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Keylogger (Capturador de Teclas) (N/A)

Software ou hardware que grava cada tecla digitada pelo usuário, capturando credenciais e dados sensíveis em texto claro antes da criptografia.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'captures keystrokes in plaintext' or 'records what a user types'. Hardware keyloggers are physically inline between keyboard and motherboard; software keyloggers are often rootkit-based.*

• Bomba Lógica (N/A)

Código malicioso que permanece adormecido até que uma condição de gatilho específica seja atendida (data, hora, evento, ação do usuário ou demissão), executando então sua carga.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'dormant until triggered by a specific event' or 'executes when condition is met'. Distinct from time bombs (date-based) vs. event-based triggers like employee termination.*

• Rootkit (N/A)

Malware que se embute profundamente no kernel do sistema operacional ou setor de boot para manter acesso privilegiado e furtivo, evadindo detecção antivírus padrão.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'malware that hides within the OS kernel' or 'invisible to standard AV'. Detection requires boot from known-good/clean media. Often necessitates full OS reinstallation.*

• Cavalo de Troia (N/A)

Malware disfarçado de software legítimo e útil para enganar o usuário a instalá-lo, entregando então uma carga maliciosa oculta.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'disguised as legitimate software' or 'user must be tricked into running it'. Does NOT self-replicate (unlike viruses/worms). Classic example: fake antivirus or game cracks.*

• Backdoor (Porta dos Fundos) (N/A)

Ponto de acesso oculto ou não documentado em software ou sistema que ignora a autenticação normal, permitindo acesso remoto do atacante.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'unauthorized access point' or 'bypasses normal authentication'. Often left by developers OR installed by Trojans. Closely linked with RATs (Remote Access Trojans).*

• **Spyware (Software Espião) (N/A)**
Malware que coleta covertamente dados sobre atividades, hábitos de navegação, credenciais ou dados pessoais do usuário sem consentimento.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'covertly gathers user information' or 'monitors browsing habits'. Distinguished from keyloggers (broader data capture) and adware (specifically ad-driven).*

• **Adware (Software de Propaganda) (N/A)**
Software que exibe ou baixa automaticamente propagandas indesejadas, geralmente empacotado com software gratuito e podendo coletar dados de marketing.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'displays unwanted advertisements' or 'bundled with free software'. Not always malicious but crosses into malware when it tracks behavior without consent (grayware).*

• **Ransomware (Software de Extorsão) (N/A)**
Malware que criptografa arquivos do usuário ou bloqueia o sistema, exigindo pagamento (resgate) tipicamente em criptomoedas pela chave de descriptografia.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'encrypts files and demands payment' or 'crypto-malware'. Modern variants use double/triple extortion (encrypt + leak + DDoS). Backups are the primary defense.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Cavalo de Troia (Trojan Horse) vs. RAT (Remote Access Trojan)

🏠 **Analogia Intuitiva:** O Cavalo de Troia da lenda grega era uma linda escultura de madeira que os troianos colocaram voluntariamente dentro de sua cidade fortificada acreditando ser um presente divino; de noite, soldados saíram da barriga da estátua e abriram os portões para o exército invasor. O Cavalo de Troia em TI faz o mesmo: parece um jogo grátis ou um leitor de PDF legítimo que o usuário instala por vontade própria. Já o RAT (Remote Access Trojan) vai além: além de entrar disfarçado, os soldados instalam no teto do palácio câmeras espiãs 360°, microfones direcionais e um controle remoto que permite ao general inimigo ligar a webcam, ler o que você digita e transferir seus arquivos a qualquer momento a partir de seu laptop na praia.

🔍 **Causa Raiz / Por que foi criado:** Cavalos de Troia exploram o elo mais fraco da cadeia de segurança: o usuário humano e a engenharia social. Como o próprio usuário concede privilégios de execução ao instalador, as defesas de perímetro (firewalls) não bloqueiam o tráfego de download. O RAT estabelece então uma conexão reversa de saída (reverse shell) para o servidor do atacante, burlando regras de entrada do firewall.

🛡️ **Visão do Auditor de GRC:** Implementar controle estrito de aplicações (Software Allowlisting / AppLocker) para que apenas binários assinados e autorizados pela empresa possam ser instalados; remover privilégios de administrador local dos usuários padrão; e monitorar conexões interativas anômalas de saída mantidas em portas altas ou encapsuladas em HTTPS.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'software that masquerades as a legitimate utility while silently executing unauthorized commands in the background'. Resposta: Trojan. Trigger: 'malware that provides an external attacker with full unauthorized interactive GUI or command-line control of an infected computer, including webcam monitoring'. Resposta: Remote Access Trojan (RAT).

📌 Rootkits & Privilégios no Kernel (Ring 0 Manipulation)

🏠 **Analogia Intuitiva:** Imagine que você suspeita de um intruso no condomínio e pede para o chefe de segurança conferir as câmeras e a lista de pessoas presentes. O que você não sabe é que o intruso subornou o próprio chefe de segurança com o cargo máximo do edifício: o chefe agora apaga a imagem do ladrão nas fitas em tempo real e risca o nome dele da lista da portaria antes de te entregar o relatório. Você olha os relatórios e acha que o prédio está vazio! O Kernel (Ring 0) é esse chefe supremo do sistema operacional: quando o rootkit infecta o Ring 0, o próprio sistema operacional mente para o antivírus e para o Gerenciador de Tarefas dizendo que aquele processo malicioso não existe.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais modernos dividem os privilégios da CPU em anéis de proteção hierárquicos: Ring 3 para aplicativos de usuários normais e Ring 0 para o núcleo (Kernel) e drivers de dispositivos. Se um malware obtém privilégios de Ring 0 (instalando um driver corrompido ou explorando vulnerabilidades de kernel), ele realiza 'System Call Hooking', manipulando as respostas das funções do sistema operacional para se tornar invisível.

🛡️ **Visão do Auditor de GRC:** Exigir a imposição rigorosa de Assinatura Obrigatória de Drivers (Driver Signature Enforcement), Secure Boot e hardware TPM. Diante da comprovação de infecção por rootkit de kernel em um ativo empresarial, a regra de ouro de GRC e resposta a incidentes é clara: nunca tente remover o rootkit com antivírus comum; formate o disco e restaure o sistema operacional a partir de uma imagem limpa homologada (Reimage/Rebuild).

⚠️ **Como cai na Prova CompTIA:** Trigger: 'malware that operates with highest kernel privileges (Ring 0), hooks system calls to hide files and processes from the OS, and persists across reboots'. Resposta: Rootkit. Ação correta de remediação recomendada pela CompTIA: Reimage / reinstall the operating system.

📌 Ransomware de Extorsão Dupla (Double Extortion Ransomware)

🏠 **Analogia Intuitiva:** No sequestro clássico (extorsão simples), o bandido invade sua casa, passa uma corrente pesada com cadeado próprio no seu cofre e cobra dinheiro pela chave; se você tiver uma cópia de todos os seus bens guardada em outro cofre seguro fora da sua casa (um backup perfeito), você dá risada e diz: 'Não pago um centavo, eu restauro meus arquivos do backup!'. Percebendo isso, os criminosos criaram a Extorsão Dupla: antes de trancar o seu cofre, eles tiram cópias fotográficas de todos os seus segredos mais íntimos, prontuários médicos e dados financeiros e ameaçam: 'Se você restaurar o backup e não nos pagar, vazaremos todos esses segredos na primeira página dos jornais mundiais amanhã de manhã!'.

🔍 **Causa Raiz / Por que foi criado:** Com a maturidade das defesas corporativas, empresas passaram a adotar backups imutáveis (WORM) e cópias offline isoladas (air-gapped backups), reduzindo drasticamente o pagamento de resgates em ataques de criptografia simples. Para restaurar o poder de chantagem, as quadrilhas passaram a exfiltrar dados sensíveis antes de disparar a rotina de criptografia, explorando o medo de multas regulatórias (GDPR/LGPD) e o dano irreparável à reputação da marca.

🛡️ **Visão do Auditor de GRC:** Ter backups não é mais controle compensatório suficiente contra ransomware moderno! O auditor de GRC deve exigir: controles rigorosos de DLP (Prevenção de Vazamento de Dados) monitorando volumes anômalos de exfiltração; criptografia de dados em repouso nos servidores de arquivos; e planos de Gestão de Crise que envolvam departamentos jurídico e de relações públicas para notificações obrigatórias de violação de dados à autoridade reguladora dentro dos prazos legais (ex: 72 horas).

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attackers encrypt files on corporate servers and threaten to publish exfiltrated sensitive data on a public leak site if ransom demands are not met'. Resposta: Double Extortion Ransomware. Pegadinha: Ter backups íntegros restaura a disponibilidade operacional, mas NÃO resolve a perda de confidencialidade da extorsão dupla.

📌 Logic Bomb & Ameaça do Funcionário Insatisfeito (Disgruntled Insider)

🏚️ **Analogia Intuitiva:** Um eletricista demitido da obra de um hospital esconde um relógio eletrônico secreto atrás da parede da UTI, programado para cortar a energia do hospital no dia 31 de dezembro, ou caso o número da sua carteira de trabalho seja deletado da folha de pagamento da construtora. Enquanto o eletricista recebe o salário todo mês, o relógio dorme em silêncio absoluto. No momento em que a construtora encerra o contrato e o remove do sistema, o gatilho é acionado e a bomba dispara o apagão.

🔍 **Causa Raiz / Por que foi criado:** Administradores de sistemas ou desenvolvedores descontentes utilizam seus privilégios legítimos para inserir trechos de código condicionais ('se condição X acontecer, execute ação Y destrutiva') em scripts ou bases de dados corporativas. Como o código permanece inerte até a satisfação do gatilho (uma data futura, um evento de demissão ou falha em um comando específico), ele evade verificações rotineiras de integridade.

🛡️ **Visão do Auditor de GRC:** Auditar o processo formal de Desligamento de Pessoal (Offboarding): revogação imediata de todos os acessos lógicos antes da comunicação formal de demissão ao colaborador; obrigatoriedade de Revisão de Código por Pares (Peer Review) e segregação de funções no ambiente de desenvolvimento; e monitoramento rigoroso de alterações em scripts de automação de infraestrutura.

> ⚠️ **Como cai na Prova CompTIA:** Trigger: 'dormant malicious code embedded by a disgruntled systems administrator that executes and deletes company databases only if the employee's ID is deleted from the HR system'. Resposta: Logic Bomb. Gatilho preventivo de GRC: Immediate account deprovisioning during employee offboarding.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Software que se disfarça de utilitário legítimo mas instala secretamente ferramentas de acesso para o invasor	**Cavalo de Troia (Trojan Horse)**
Malware que permite ao atacante controlar remotamente a máquina da vítima com interface gráfica e acesso à webcam	**Trojan de Acesso Remoto (RAT - Remote Access Trojan)**
Código malicioso em nível de kernel (Ring 0) que manipula chamadas de sistema para ocultar seus processos dos relatórios do SO	**Rootkit (procedimento de correção: Reimage / reinstalar o SO)**
Atacantes criptografam servidores corporativos e ameaçam publicar dados confidenciais na internet se o resgate não for pago	**Ransomware de Extorsão Dupla (Double Extortion)**
Código dormente inserido por funcionário insatisfeito que dispara a exclusão de arquivos se uma data chegar ou o usuário for demitido	**Bomba Lógica (Logic Bomb)**
Melhor prática de GRC para mitigar o risco de sabotagem de dados por um colaborador em vias de demissão	**Revogação Imediata de Credenciais no Offboarding (Offboarding Deprovisioning)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista financeiro relata que credenciais do portal bancário interno foram roubadas mesmo com o portal usando HTTPS. A análise forense mostra um pequeno processo em modo usuário na estação de trabalho interceptando a digitação antes de o navegador criptografá-la. Qual tipo de malware melhor corresponde a esse comportamento?

A) Keylogger

B) Rootkit

C) Logic bomb

D) Adware

QUESTÃO 2 · CENÁRIO DE EXAME

Um ex-contratado deixa um script em um servidor de arquivos. O script verifica a cada hora e, se o registro de RH do contratado estiver marcado como demitido, apaga arquivos de projeto e desativa backups. O código permanece dormente por semanas até essa condição ocorrer. Qual tipo de malware é este?

A) Ransomware

B) Rootkit

C) Logic bomb

D) Cavalo de Troia

QUESTÃO 3 · CENÁRIO DE EXAME

Durante a resposta a incidentes, analistas descobrem que um servidor Linux comprometido mostra listas de processos normais e varreduras antivírus não indicam infecção. No entanto, tabelas de chamadas de sistema do kernel foram modificadas, e um driver malicioso oculta arquivos e conexões de rede. Qual tipo de malware provavelmente está presente?

A) Keylogger

B) Rootkit

C) Adware

D) Logic bomb

QUESTÃO 4 · CENÁRIO DE EXAME

Um funcionário baixa o que parece ser um conversor gratuito de PDF para Word de um anúncio pop-up. O programa converte PDFs como prometido, mas também instala um serviço de acesso remoto que aguarda comandos de um endereço IP externo. Qual tipo de malware melhor descreve o conversor?

A) Keylogger

B) Ransomware

C) Logic bomb

D) Cavalo de Troia

QUESTÃO 5 · CENÁRIO DE EXAME

Depois que uma estação de trabalho é limpa de uma infecção anterior, a equipe de segurança observa conexões de entrada recorrentes para uma porta TCP alta. Análise adicional mostra um serviço oculto que aceita comandos usando uma credencial embutida, permitindo acesso sem explorar novamente a vulnerabilidade original. Que mecanismo é este?

A) Backdoor

B) Rootkit

C) Spyware

D) Logic bomb

QUESTÃO 6 · CENÁRIO DE EXAME

Uma ferramenta de segurança de endpoint alerta sobre um processo que envia periodicamente histórico de navegação, conteúdo da área de transferência e títulos de janelas de aplicativos para um servidor externo. Usuários relatam nenhum anúncio pop-up e nenhum arquivo foi criptografado. Qual categoria de malware melhor corresponde a essa atividade?

A) Adware

B) Spyware

C) Ransomware

D) Logic bomb

QUESTÃO 7 · CENÁRIO DE EXAME

Funcionários que instalaram um pacote gratuito de protetor de tela relatam anúncios pop-up frequentes, página inicial do navegador alterada e novas barras de pesquisa. Nenhuma credencial ou documento parece ter sido roubado. Qual categoria de malware provavelmente está envolvida?

A) Spyware

B) Keylogger

C) Adware

D) Rootkit

QUESTÃO 8 · CENÁRIO DE EXAME

Arquivos de um compartilhamento de rede de um hospital são substituídos por versões criptografadas com extensão .locked. Um arquivo de texto em cada sistema afetado exige pagamento em criptomoeda em troca de uma chave de descriptografia. Qual tipo de malware é responsável?

A) Rootkit

B) Cavalo de Troia

C) Adware

D) Ransomware

QUESTÃO 9 · CENÁRIO DE EXAME

Um servidor comprometido é confirmado como tendo código malicioso em nível de kernel que oculta processos e modifica chamadas de sistema. O sistema operacional não pode ser confiável, e a equipe de resposta a incidentes precisa da maneira mais confiável de remover a ameaça. O que a equipe deve fazer?

A) Executar uma varredura antivírus completa e excluir arquivos detectados

B) Apagar o servidor e reinstalar o SO de mídia confiável

C) Remover o processo malicioso pelo Gerenciador de Tarefas

D) Alterar todas as senhas de administrador local

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista de segurança suspeita que uma estação de trabalho está capturando credenciais do usuário antes de serem criptografadas pelo navegador. O analista tem monitoramento baseado em host e de rede disponíveis. Qual fonte de dados tem maior probabilidade de revelar essa atividade?

A) Captura de pacotes de rede filtrando apenas tráfego HTTPS

B) Logs de firewall de perímetro mostrando conexões de entrada bloqueadas

C) Monitoramento de API e de digitação baseado no host na estação de trabalho

D) Logs de consultas DNS para o domínio do portal bancário

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Keylogger

Um keylogger captura as teclas na camada de entrada antes da criptografia TLS/HTTPS, podendo roubar credenciais em texto claro. Rootkits se escondem no kernel, logic bombs disparam por eventos específicos e adware exibe anúncios indesejados. HTTPS não protege contra captura local de digitação.

Questão 2: Alternativa C — Logic bomb

Um logic bomb é um código dormente que executa uma carga maliciosa quando um gatilho específico ocorre. Aqui o gatilho é o status de demissão no RH, após o qual ele apaga arquivos e desativa backups. Ransomware exige pagamento, rootkits se escondem no kernel e cavalos de Troia se disfarçam de software legítimo.

Questão 3: Alternativa B — Rootkit

Um rootkit frequentemente modifica componentes do kernel ou chamadas de sistema para ocultar arquivos, processos e conexões de ferramentas normais e antivírus. Keyloggers capturam entrada, adware exibe anúncios e logic bombs disparam por eventos. O ocultamento em nível de kernel aponta para um rootkit.

Questão 4: Alternativa D — Cavalo de Troia

Um cavalo de Troia parece executar uma função legítima enquanto secretamente realiza ações maliciosas. O conversor funciona como anunciado, mas também instala um serviço de acesso remoto. Um keylogger captura teclas, ransomware criptografa para pedir pagamento e um logic bomb espera por um gatilho.

Questão 5: Alternativa A — Backdoor

Um backdoor é um mecanismo de acesso oculto que permite ao atacante reconectar sem explorar novamente a vulnerabilidade original. Ele pode usar um serviço em escuta e credenciais embutidas. Um rootkit oculta atividade, spyware coleta informações e um logic bomb dispara por um evento.

Questão 6: Alternativa B — Spyware

Spyware coleta secretamente a atividade e os dados do usuário, como histórico de navegação, conteúdo da área de transferência e títulos de janelas. Adware foca em anúncios indesejados, ransomware criptografa arquivos para pedir pagamento e logic bombs disparam uma carga por um evento. A coleta furtiva de dados é spyware.

Questão 7: Alternativa C — Adware

Adware exibe anúncios indesejados e frequentemente altera configurações do navegador, como página inicial e barras de pesquisa. Spyware coleta informações furtivamente, um keylogger captura teclas e um rootkit se oculta no kernel. Os sintomas focados em anúncios apontam para adware.

Questão 8: Alternativa D — Ransomware

Ransomware criptografa dados e exige pagamento por uma chave de descriptografia. Um cavalo de Troia pode entregá-lo, mas a carga descrita é extorsão por criptografia. Rootkits ocultam atividade, e adware exibe anúncios.

Questão 9: Alternativa B — Apagar o servidor e reinstalar o SO de mídia confiável

Comprometimento em nível de kernel torna o sistema operacional não confiável, então a remediação mais confiável é apagar o servidor e reinstalar o SO de mídia confiável. O antivírus pode não detectar código oculto no kernel, encerrar um processo é insuficiente, e alterar senhas não remove os componentes maliciosos do kernel.

Questão 10: Alternativa C — Monitoramento de API e de digitação baseado no host na estação de trabalho

Se as credenciais são capturadas antes da criptografia do navegador, a atividade ocorre localmente na estação de trabalho. Monitoramento de API e de digitação baseado no host pode detectar isso. Captura de pacotes HTTPS mostraria tráfego criptografado, logs de firewall mostram conexões bloqueadas, e logs de DNS mostram consultas de domínio, mas não digitação.